

Security Fundamentals

Fundamental Aspects of Security

- **What is Computer Security?**
 - The protection of valuable items, called **assets**, of a computer or computer system.
 - **Assets** can be hardware, software, data, people, processes, or combinations.
- **Values of Assets**
 - The value of an asset depends on the owner/user's view.
 - Values are personal, time-dependent, and often not exact.
- **The Vulnerability-Threat-Control Paradigm**
 - A framework to describe how assets can be harmed and how to stop or lessen that harm.
 - **Vulnerability**: A weakness that can be used to cause harm (e.g., in procedures, design, or implementation). Example: A system not verifying user identity before allowing data access.
 - **Threat**: A situation that could cause harm or damage. It is a potential danger.
 - **Attack**: When a human or another system uses a vulnerability to cause harm. Example: A Denial of Service (DoS) attack where a system is flooded with messages.
 - **Control (or Countermeasure)**: An action, device, procedure, or technique that removes or reduces a vulnerability, thus blocking a threat.
- **C-I-A Triad**
 - These are three core properties in computer security:
 - **Confidentiality**: Ensures assets (especially data) are seen **only by authorized parties**.
 - **Failure Examples**: Unauthorized person or program accesses data, or even learns its existence or approximate value.
 - **Best Practices**: Handle data based on privacy needs, **encrypt data**, use **Two-factor authentication (2FA)**, keep access control lists updated.
 - **Integrity**: Ensures assets (especially data) are **modified only by authorized parties** and remain accurate, complete, and trustworthy throughout their life. Data must not be changed in transit.

- **Best Practices**: Employees should know compliance rules, use **backup and recovery software**, use **version control**, **access control**, **security control**, **data logs**, and **checksums**.
 - **Availability**: Ensures assets can be **used by authorized parties** when needed, without undue delay. Systems, networks, and applications must function correctly.
 - **Best Practices**: Use **redundancy**, **failover**, and **RAID**, keep systems updated, use **network/server monitoring**, have a **data recovery and business continuity plan**.
- **Harm Characterization**
 - Harm to assets can be described by four actions: **interception**, **interruption**, **modification**, and **fabrication**.
-

Security Implementation Mechanisms

1. Guards in Information Security

- **What they are**: Security mechanisms that **protect assets and resources from unauthorized access and threats**. They are the **first line of defense**.
- **Purpose**: To **protect assets, systems, or data** from unauthorized access, attacks, and threats.
- **Focus**: Taking **preventive security actions**.
- **Role**: Act as **barriers to defend against security threats**.
- **Examples**:
 - **Firewall**: Controls network traffic based on security rules.
 - **Intrusion Detection System (IDS)**: Detects unauthorized access or security breaches.
 - **Intrusion Prevention System (IPS)**: Similar to IDS, but can also **block and prevent threats**.
- **Importance**:
 - **Adaptive Security**: Helps organizations respond to new attacks.
 - **Threat Detection**: Finds suspicious activities in real-time.
 - **Threat Response**: Allows quick action against threats.
 - **Multi-Layered Defense**: Using multiple guards makes it harder for attackers.

2. Gates in Information Security

- **What they are:** **Control mechanisms** that manage access points and **decide whether to allow or deny access** to a resource based on rules.
- **Purpose:** To **control access to specific resources** based on certain rules.
- **Focus:** Controlling **who can access resources and be authorized**.
- **Role:** Act as **entry points or barriers** users must pass through.
- **Examples:**
 - **Access Control Gates:** Verify user identity for network or system access.
 - **Authorization Gates:** Decide what resources authenticated users can access.
 - **Encryption Gates:** Use encryption to control access to sensitive information.
- **Importance:**
 - **Access Control:** Manages who can reach resources, systems, or data.
 - **Authorization:** Determines what authenticated users can access.
 - **Encryption:** Protects sensitive data during transfer or storage.
 - **Authentication:** Confirms who can access resources.

3. Cryptography

- **What it is:** A technique using **mathematical rules to convert readable data (plaintext) into unreadable data (ciphertext)** for unauthorized users.
- **Techniques:**
 - **Symmetric Key Encryption:** Uses **one shared key** for both encrypting and decrypting data.
 - **Asymmetric Key Encryption:** Uses a **public key for encryption** (freely distributed) and a **private key for decryption** (kept secret).
 - **Hash Functions:** Change data into a **fixed-size string (hash value)** to create unique identifiers.
 - **Digital Signatures:** Create unique signatures to **check if digital documents are real and haven't been changed**.
- **Importance:**
 - **Data Protection:** Keeps data safe from unauthorized access.
 - **Confidentiality:** Ensures only authorized people can see sensitive data.
 - **Data Integrity:** Detects changes in encrypted data.
 - **Authentication:** Verifies if a message is real.
 - **Non-Repudiation:** Provides proof of where a message came from.
 - **Secure Key Management:** Safely handles encryption keys.

4. Steganography

- **What it is:** A technique to **hide secret information inside non-secret data** (like images, audio, text files) to make the hidden information's existence unknown.
- **Importance:**
 - **Covert Communication:** Allows hidden messages.
 - **Hidden Information:** Helps transmit confidential data without drawing attention.
 - **Enhanced Security:** Provides an extra layer of security when used with cryptography.
 - **Preventing Information Leakage:** Protects sensitive data from being accidentally or maliciously exposed.
 - **Forensics:** Used by investigators to find hidden evidence of illegal activities.

5. Cryptography vs. Encryption

- **Encryption:** **Converts plaintext into ciphertext**. Its goal is primarily to ensure **confidentiality**.
- **Cryptography:** A **broader field of securing data and communications**. Its goal includes **confidentiality, integrity, authenticity, and non-repudiation**. Encryption is a method *used* in cryptography.

6. Cryptography vs. Cyber Security

- **Cryptography:** Focuses on **securing data using mathematical algorithms**.
- **Cyber Security:** A **broader field of protecting networks, devices, software, and data** from harm or unwanted access. Cryptography is one of the techniques used within cybersecurity.

Information Assurance Analysis Models

- **Information Assurance (IA)**
 - **Definition:** Focuses on protecting and safeguarding critical information and related systems by ensuring **confidentiality, integrity, availability, and non-repudiation**.
 - **Approach:** A strategic approach focused more on **policies** than building infrastructure.
- **Information Assurance Model**
 - A structured way to protect and manage information.

- It is a **multidimensional model** based on four dimensions:
 1. **Information States**
 2. **Security Services**
 3. **Security Countermeasures**
 4. **Time**
- **Information States**
 - Information (interpretation of data) exists in three states:
 1. **Transmission**: Data is moving between processing steps, e.g., in transit over networks (email).
 2. **Storage**: Data is saved on a medium, e.g., on a hard drive.
 3. **Processing**: Data is actively being processed, e.g., in RAM.
- **Security Services**
 - These are the fundamental pillars of the IA model:
 1. **Confidentiality**: Protecting data from unauthorized access, ensuring only authorized people can view it. Uses **encryption, access controls, secure communication protocols**. Example: Strong encryption (AES, RSA) for customer data.
 2. **Integrity**: Ensuring data remains **accurate, complete, and unaltered** throughout its life. Uses **data validation, checksums, digital signatures**. Example: Banking systems checking transaction rules to prevent incorrect account numbers.
 3. **Availability**: Ensuring resilient systems and processes so information is accessible when needed. Involves **backup and disaster recovery, redundancy, proactive monitoring**. Example: E-commerce website using synchronized servers and load balancers for uninterrupted service.
 4. **Authentication**: Verifying an individual's identity to grant access to information. Uses single-factor (e.g., username/password) or **multi-factor authentication (MFA)**. Example: Logging into a website with username and password.
 5. **Non-Repudiation**: Ensures the **origin and integrity of data cannot be denied by the sender**. Uses **digital signatures, audit trails, timestamping**. Example: Digital signatures on documents prevent signers from later denying their involvement.

- **Security Countermeasures**
 - Functionalities to protect the system from vulnerabilities, considering:
 - **People**: Administrators and users must follow policies and be informed to safeguard the system.
 - **Policy & Practice**: Organizations define rules that individuals must follow to handle sensitive information, especially when systems are compromised.
 - **Technology**: Use appropriate technology like **firewalls, routers, and intrusion detection** to defend against threats and enable quick response.
- **Best Practices of Information Assurance Model**
 - **Access Controls**: Control who can access sensitive data using secure passwords, **two-factor authentication**, and role-based access control.
 - **Encryption**: Transforms sensitive information into a secret code (ciphertext) for protection. Uses **Transport Layer Security (TLS)** to secure communication.
 - **Patch Management**: Regularly apply security patches and updates to software and devices to fix vulnerabilities.
 - **Employee Awareness Training**: Educate employees to identify phishing, practice good password habits, and report suspicious activities.
 - **Incident Response**: Have a plan to minimize damage, investigate breaches, and restore operations quickly during a security incident.

Disaster Recovery

- **Disaster**
 - Events that disrupt or completely stop a business.
 - Can be natural (e.g., hurricanes, floods), cyberattacks (e.g., malware, DDoS), intentional human-caused threats (e.g., terrorism), or technological hazards (e.g., power outages).
- **Disaster Recovery (DR) Plan**
 - **Definition**: An organization's ability to restore access and functionality to IT infrastructure after a disaster.
 - **Purpose**: To minimize the impact of disruptions, achieve faster recovery, and quickly resume operations.

- **IT Disaster Recovery:** Policies, tools, and processes specifically for recovering IT infrastructure, software, and systems.
- **Cloud in Disaster Recovery**
 - The cloud is considered the **best solution** for business continuity and disaster recovery.
 - It **eliminates the need for a separate disaster recovery data center**.
 - DR for cloud-based systems is **critical** for overall business continuity.
- **Elements for Recovery in DR Plan**
 - **Preventive:** Measures to stop a disaster from happening, like backing up data or monitoring environments.
 - **Detective:** Measures to find out when unwanted events are happening in real-time for rapid response.
 - **Corrective:** Planning for DR scenarios, ensuring backup operations, and putting recovery procedures into action to restore data and systems quickly.
- **Disaster Recovery Site**
 - A secondary location where critical data and workloads are replicated and backed up.
 - Used to recover data from backups or as a switch-over point if the primary location fails.
- **Types of Disaster Recovery**
 - **Backups:** Copying data offsite, but without IT infrastructure.
 - **Backup as a Service (BaaS):** Regular data backups provided by a third-party.
 - **Disaster Recovery as a Service (DRaaS):** Cloud providers back up your data and IT infrastructure on their cloud, and manage your DR plan during a crisis.
 - **Point-in-time snapshots:** Replicates data/files/databases at a specific moment. Data loss can occur depending on snapshot frequency.
 - **Virtual DR:** Backs up operations/data or creates a full replica on offsite virtual machines (VMs). Allows quick resumption of operations.
 - **Disaster recovery sites:** Physical locations with data/systems backups.
- **Benefits of Disaster Recovery**
 - **Stronger business continuity:** Ensures operations can recover with minimal interruption.

- **Enhanced security:** Data backup and other procedures strengthen security and limit attack impact. Cloud DR offers encryption and access management.
- **Faster recovery:** Restores data and workloads quickly, minimizing downtime.
- **Reduced recovery costs:** Avoids or minimizes financial impacts like lost business, productivity, and penalties.
- **High availability (HA):** Many cloud services have HA features (redundancy, automatic failover) to support DR.
- **Better compliance:** Supports regulatory requirements by defining data protection procedures and testing.
- **Planning a Disaster Recovery Strategy**
 - Should include emergency response, backup operations, and recovery procedures.
 - Often part of a broader **business continuity strategy**.
 - Key metrics to consider:
 - **Recovery Time Objective (RTO):** Maximum acceptable time systems/applications can be down without significant damage.
 - **Recovery Point Objective (RPO):** Maximum age of data you need to recover to resume operations; defines backup frequency.
 - These metrics are used in **risk assessments** and **business impact analysis (BIA)** to define DR goals.
- **What is Disaster Recovery Used For?**
 - Ensuring **business resilience**.
 - Maintaining **competitiveness** by preventing customers from going to competitors.
 - Avoiding **regulatory risks** and heavy fines.
 - Avoiding **data loss**.
 - Keeping **customers happy** and meeting service level agreements (SLAs).
 - Maintaining **reputation** and preventing brand damage.

Notes from "Topic 5 Operational Issues and Policies.pdf"

- **Operational Issues**
 - Relate to daily processes and how a company operates.

- Policies and mechanisms must balance protection benefits against the cost of design, implementation, and use.
- **Cost-Benefit Analysis**
 - Compares the benefits of computer security against its total cost (including costs if the system is compromised).
 - Security mechanisms are not cost-effective if the data or resources are cheaper to reconstruct than to protect.
- **Risk Analysis**
 - **Definition:** Analyzing potential threats to an asset and how likely they are to happen, to decide if and how much to protect the asset.
 - **Level of protection** depends on the probability and effects of a successful attack.
 - **Steps:**
 - **Assessing Risk Probability:** Not all attacks are equally likely. Prioritize protection against more likely threats.
 - **Considering Impact:** The severity of an unlikely attack can outweigh its low probability (e.g., an unlikely attack with a significant impact on production is more critical than a likely, but minor, nuisance attack).
 - **Balancing Probability and Impact:** Resource allocation balances the likelihood of an event with its potential severe consequences.
- **Policies, Procedures, Standards, and Guidelines**
 - **Policies:** High-level, broad statements from management about what the organization wants to achieve on a security issue.
 - **Procedures:** Step-by-step instructions on how to implement policies; describe exactly how employees should act.
 - **Standards:** **Mandatory elements** for implementing a policy; established criteria that must be met.
 - **Guidelines:** **Recommendations or suggestions** that offer flexibility; not mandatory steps.

Attacks in Information Security

1. Attack & Cyber Attack

- **Attack:** An information security threat involving **unwanted activities** like viewing, changing, destroying, or revealing information without

permission. Examples include unauthorized access, stealing data, or harming systems.

- **Cyber Attack:** A specific type of attack that **exploits weaknesses in digital systems, networks, and technologies**. Attackers use specific methods or pathways.

2. Types of Cyber Attacks

- **Active Attacks:** Where an attacker **directly communicates with the target system to modify, disrupt, or destroy it**.
 - **Masquerade:** Attacker **pretends to be a legitimate user** to gain access to a system or data.
 - **Replay:** Attacker **saves a copy of data** from a network and **uses it later** to gain access.
 - **Repudiation:** Attacker **denies actions** they have taken, like making a transaction or sending a message.
 - **Modification of Messages:** Attackers **change, alter, delay, or re-order digital messages**, attacking data integrity.
 - **Denial of Service Attacks (DoS):** **Flooding a system or network with traffic or requests** to make it slow down or stop working, so legitimate users can't access it.
 - **Occurring Ways:** Flooding the target with too much network traffic, or overloading it with too many requests.
 - **Ways to Control:** Firewalls, DoS Detection Systems, limiting requests, using load balancers.
- **Passive Attacks:** Where an attacker **secretly watches a system to learn about it, without directly harming it**.
 - **Traffic Analysis:** **Monitoring data flow** to learn about communication patterns and system behavior.
 - **Eavesdropping:** **Secretly listening** to conversations, like phone calls or reading unencrypted messages.
 - **Footprinting:** **Collecting information about a target company's digital presence** (hardware, software, network, employees).
 - **War Driving:** Driving around with a special antenna **looking for weak Wi-Fi spots** to get free internet.
 - **Packet Sniffing:** **Capturing and analyzing data packets** as they travel over a network to gain unauthorized access to sensitive information.
 - **Wiretapping:** **Illegally listening to phone calls** or other communication signals.
 - **Network Mapping:** Attacker **creates a map of the network** by monitoring traffic and identifying device communication patterns.

3. Common Attack Vectors

- **Attack Vector:** The **pathway or method a hacker uses** to illegally access a network or computer and exploit weaknesses.
- **Types:**
 - **Social Engineering: Manipulating people** to reveal confidential information or do things they shouldn't.
 - **Phishing:** Tricking users by **pretending to be a trustworthy person/organization** to steal data (e.g., fake bank emails).
 - **Pretexting:** Someone creates a **fake story or scenario** to get private data (e.g., message about winning a gift asking for card details).
 - **Baiting:** Leaving a **tempting trap** to get information (e.g., USB drive labeled "free games" with harmful software).
 - **Software Vulnerability: Exploiting weaknesses (bugs)** in systems to gain control or disrupt functions.
 - **Zero-day Exploit:** Attacks that happen **on the same day a software weakness is discovered**.
 - **Password Attack:** Trying to gain unauthorized access by **cracking passwords**.
 - **Brute Force Attack:** Using automated scripts to **guess passwords by trying many combinations**.
 - **Dictionary Attack:** Using a **list of common or leaked passwords**.
 - **Credential Attack:** Using **passwords obtained from a data breach** to try logging into other websites.
 - **Malware: Malicious software** delivered in files or code to damage or exploit systems.

4. Impact of Attacks

A successful attack can cause significant damage to a business.

- **Financial Impact:** Direct and indirect money losses.
 - **Direct Costs:** Data recovery, system repair, higher insurance.
 - **Indirect Costs:** System downtime, lost productivity, decreased sales, project delays, legal fees.
- **Reputational Damage:** Harm to an organization's image, brand, and overall reputation.
 - Loss of sales, customer dissatisfaction, loss of customers, reduced profits, social media backlash.

- **Legal and Regulatory Consequences:** Legal actions and penalties for not following laws and regulations that led to the attack.
 - Compensation for data breaches, penalties for failing data protection laws, needing to notify people about exposed data.

5. Defense Mechanisms

- **Cyber Security Best Practices:**
 - Use **strong passwords**.
 - Utilize **multi-factor authentication**.
 - Keep **software up to date**.
 - Conduct **employee security awareness training**.
 - Use **data encryption**.
 - Assign **user privileges (authorization)** carefully.
- **Intrusion Detection and Prevention:**
 - Deploy systems to **monitor network and system activities**.
 - **Automatically respond and block malicious activities**.
 - Take **preventive actions**.
- **Incident Response:**
 - Have a structured plan to **manage security incidents**.
 - Develop a **well-defined response plan**.
 - Establish a **dedicated team for quick and effective response**.
- **Firewalls and Network Security:**
 - **Control incoming and outgoing traffic**.
 - Utilize intrusion prevention.
- **Encryption:**
 - **Encrypt sensitive data**.
 - Implement **strong encryption algorithms**.
- **Endpoint Security:**
 - Use **antivirus programs**.
 - Use **anti-malware software**.
 - Implement **device control measures**.

Forensics

- **Computer Forensics (also Digital Forensics / Cyber Forensics)**
 - **Definition:** Applying investigation and analysis methods to **gather and preserve evidence** from computing devices, suitable for legal use.

- **Goal:** To conduct a structured investigation with a **documented chain of evidence** to find out what happened on a device and who was responsible.
- **Not just for crime:** Also used for **data recovery** from crashed servers, failed drives, etc..
- **Digital Evidence**
 - Information collected from devices. Two types:
 1. **Volatile data:** Digital information stored in a temporary medium, **lost when the device is powered off**. Examples: RAM, network connections, open files, running processes.
 2. **Nonvolatile data:** Digital information stored in permanent mediums, **not lost when the device is switched off**. Examples: Hard disks, system files, event logs, account information. Less tricky to retrieve.
- **Key Purposes of Computer Forensics**
 1. **Investigate allegations of digital malfeasance:** Investigating crimes involving digital media or computer technology.
 2. **Perform root cause analysis:** Examining how unauthorized access was gained and how widespread an attack was.
- **Importance of Computer Forensics**
 - **Legal compliance:** Helps maintain compliance with data privacy rules, reducing legal risks.
 - **Risk mitigation:** Identifies vulnerabilities proactively to minimize cyberattacks.
 - **Faster incident response:** Expedites response to incidents, helping data recovery and identifying responsible parties.
 - **Cost savings:** Prevents and mitigates digital incidents, saving costs from data breaches.
- **Types of Computer Forensics**
 - **Database forensics:** Examines data and metadata in databases.
 - **Email forensics:** Recovers and analyzes emails, schedules, contacts.
 - **Malware forensics:** Sifts code to identify malicious programs (e.g., Trojans, ransomware, viruses).
 - **Memory forensics:** Collects information from RAM and cache.
 - **Mobile forensics:** Examines mobile devices for contacts, messages, pictures, videos.
 - **Network forensics:** Monitors network traffic using tools like firewalls or IDS to find evidence.
- **When to Use Computer Forensics**

- **Data breaches:** Identify source, extent of damage, and remedial actions.
- **Fraud investigations:** Uncover digital evidence for suspected fraud.
- **Intellectual property theft:** Track stolen IP and identify culprits.
- **Employee misconduct:** Provide evidence for misuse of company resources or policy violations.
- **Legal disputes:** Retrieve, analyze, and present digital evidence in court.
- **Process of Computer Forensics**
 0. **Identification:** Locating potential sources of digital evidence.
 1. **Preservation:** Protecting evidence from alteration or destruction.
 2. **Collection:** Gathering evidence using forensically sound methods.
 3. **Analysis:** Examining evidence to find relevant information and draw conclusions.
 4. **Presentation:** Organizing and presenting findings clearly and for legal admissibility.
- **Techniques Forensic Investigators Use**
 - **Reverse steganography:** Analyzes data hashing to uncover hidden data in files. Hidden information changes the underlying data hash.
 - **Stochastic forensics:** Reconstructs digital activity **without digital artifacts** (unintended data alterations). Used when attackers (e.g., insiders) might not leave artifacts.
 - **Cross-drive analysis:** Compares information across multiple computer drives to find similarities and context for suspicious events (anomaly detection).
 - **Live analysis:** Analyzes a running computer from within its OS, looking at **volatile data** (cache, RAM) using system tools.
 - **Deleted file recovery (file carving / data carving):** Searches systems/memory for fragments of partially deleted files.
- **Digital Forensics Tools**
 - Can be hardware or software. Used to inspect devices while keeping data integrity.
 - Examples: File analysis tools, Network analysis tools, Database analyzers, Registry tools (for Windows user activity), Data capture tools (for persistent disks), Email scanners, Mobile device scanners.

Cloud Computing (Additional)

1. What is Cloud Computing?

- **Definition: On-demand delivery of different services over the internet** with a "pay-as-you-go" pricing model.
- **Services it provides:** Email, storage, backup, data retrieval, app creation and testing, data analysis, audio/video streaming, software delivery on demand.

2. Cloud Computing Deployment Models

1. **Public Cloud:** Services available to anyone over the public internet, owned by a third-party provider.
2. **Private Cloud:** Cloud infrastructure used by a **single organization**, hosted either on-premises or by a third party.
3. **Hybrid Cloud:** A **combination of both public and private clouds**, allowing data and applications to be shared between them.
4. **Community Cloud:** Cloud infrastructure **shared among several organizations with common concerns**.

3. Key Characteristics of Cloud Computing

1. **On-Demand Self Service:** Users can get computing resources without human help from the service provider.
2. **Broad Network Access:** Services can be accessed from **anywhere and any device**.
3. **Resource Pooling:** Resources are shared and assigned to multiple users based on demand.
4. **Elasticity:** You **pay only for what you use**, and resources can quickly scale up or down.
5. **Measured Service:** Resource usage is tracked and billed based on consumption.
6. **Fault Tolerance and Reliability:** Cloud providers have systems to ensure **high availability** and reliability of services.
7. **Scalability:** Cloud services can easily grow to handle more work and users.

4. Types of Cloud Services

- **Cloud Services:** Infrastructure, platforms, or software hosted by third-party providers and available over the Internet.
- **Types:**
 - **Infrastructure-as-a-Service (IaaS):** Provides **highly scalable computing resources** (like virtual machines, storage) over the

internet, eliminating physical infrastructure. You pay only for what you use.

- **Software-as-a-Service (SaaS):** Accessing **software applications over the internet on a subscription basis**. The provider handles hosting and maintenance, so users don't need to install or manage it.
- **Platform-as-a-Service (PaaS):** Offers a **complete cloud environment for developers to build, run, and manage applications**. This includes servers, operating systems, storage, and tools.

5. Advantages of Cloud Computing

- Pay As You Go Model
- High Availability
- Easy to Manage
- Dynamic Scaling
- Disaster Recovery and Business Continuity
- Environmental Sustainability
- Security (managed by provider, but still a shared responsibility)

6. Disadvantages of Cloud Computing

- Dependency on Internet Connectivity
- Cost Overruns Due To Over Provisioning of Resources
- Downtime and Outages of Cloud Service Providers
- Security and Data Privacy Concerns (shared responsibility model)
- Data Transfer and Bandwidth Costs

7. Popular Cloud Service Providers

- AWS (Amazon Web Services)
- Microsoft Azure
- Google Cloud Platform (GCP)